

Mitigating Malware & Ransomware Risks:

A Publisher's Guide

Alex MacIntyre

Introduction - *Evolving Technologies & Threats*

The publishing industry has undergone a change that few other sectors have can claim to have matched. Hardware like printing presses, typewriters, and the telegraph created an industry that forged the path for modern communications. Hardware mechanized communication, and software has virtualized and personalized it. The author's notes, once sprawled across a desk, teetering towards the ground, are now represented by a cluttered desktop, full of icons representing projects and annotations, with anything else crossing their mind scattered in between. More than authors, accountants, marketers, design, production, sales, and every other human component of the business have a similar story. Their jobs, and their lives are all vividly depicted on screen, turning their unfinished work and their confidential work alike into high-value assets. Where there are assets, there is a target, and the value of the works generated in the publishing industry, and thus, the information protected by a publishing firm, paint a target for malicious actors.

In 2023, Canadian retailer Indigo Books & Music suffered losses of nearly \$19 million from a ransomware attack [1]. In early 2025, major UK printing firm CPI was hit with a ransomware attack that forced them to halt production on over 160 million books, causing a strain on the industry that made shockwaves to the global supply chain [2], leading publishers to find more costly alternatives. Once digital operations stop, physical operations do too. This can happen to publishers too, and the risk cannot be eliminated. This report outlines five major vulnerabilities faced by publishers, and mitigation strategies to decrease their harm in the event of an attack and to lower their likelihood overall.

The Human Firewall - *Mitigating Social Engineering and Phishing*

The most common entry point for cyberattacks is through flaws found within the people who access them. Corporate controls are being bypassed when business matters are conducted on "out-of-bounds" platforms like personal social media or unsecured personal email accounts. This behavior creates an environment where "social engineering" is possible, where attackers manipulate employees

into divulging confidential information. Bad actors utilize "phishing" attacks to exploit this vulnerability. Bad actors utilize "phishing" attacks to exploit this vulnerability. For a publisher, this often manifests as a spear-phishing email from a fake "literary agent" or "author" containing an infected attachment labeled "Draft Revision". A single click can grant an attacker credentials to the firm's network. The financial implications are massive; the median ransom payment reached \$2.0 million in 2024 [3]. That number doesn't include the immense costs of system recovery and operational downtime, which could be substantially higher. The strongest mitigation strategy is to build a workforce trained to identify threats and resist them. **This involves two tactical steps:**

1. **Continuous Training Exercises** - Implement regular, simulated phishing campaigns tailored to the industry (e.g. Test emails from "authors" with "revised drafts") to test and train employee awareness.
2. **Advanced Email Security** - Utilize modern security software that scans and blocks sophisticated spoofing emails before they ever reach an employee's inbox.

Data Backup & Recovery Plans - *To Lose Less, Strategize for Loss*

An attacker may fall through the cracks of the first mitigation strategy and gain access. If this happens, they will likely activate ransomware. This is a virus that hides your data through "encryption", and demands a payment to unlock it. Once every file is locked up, attackers often target backup servers to ensure that they are the only ones that can restore operations, creating a situation where payment is the only way out. This can cause downtime, and without secure backups, creative inventory, like manuscripts, cover art, and contracts, are permanently lost. In 2023, the British Library faced attacks from the Rhysida ransomware group, resulting in recovery costs estimated between £6–7 million [4]. A similar loss of intellectual property for a commercial publisher could be fatal to the business's reputation and bottom line. **Adopt the 3-2-1 Backup Rule, and create a strong recovery plan to minimize these risks:**

3. **Copies:** Maintain 3 copies of all critical data though network attached backups and shared disks.
2. **Media Types:** Store these copies on 2 different media types like network storage and cloud backups..
1. **Offline Copy:** Keep 1 copy completely offline and off-site.

Access Control & Network Segmentation - *Contain the Blast Radius*

Many organizations operate on a "flat" network, where one password grants access to everything. This architecture is dangerous because if an intern's computer is compromised, the attacker can move laterally to the finance or editorial servers without restriction. During the 2023 ransomware attack on Indigo Books & Music, the LockBit ransomware spread partially due to insufficient network segmentation. Having one point of entry for everybody created a shutdown that cost millions of dollars to recover from. **Strict access control and network segmentation is crucial to minimizing this risk:**

1. **Implement the Principle of Least Privilege (PoLP):** Conduct a formal review of user permissions across all key systems. Choose what to allow by the job that needs to be done, and only allow what is needed.
 2. **Enforce Multi-Factor Authentication (MFA):** Enforce for all logins to make sure that stolen credentials alone does not lead to a compromised account.
 3. **Segment the Network:** Create separate virtual networks for different operational units. For example, the corporate Wi-Fi for guest devices should be entirely separate from the network housing the editorial and design servers.
-

Patch Management - Closing the Digital Backdoor

Flaws are everywhere, and many go unnoticed until after the fact. In publishing, this is where a copy editor comes in. When dealing with cybersecurity, this is where updates come in. Updates act quickly to fix problems known as vulnerabilities. Cybercriminals are always looking for them, and the easiest targets are systems that haven't been updated. A vulnerability in a widely used PDF reader or font-rendering software can act as an unlocked door, and it could lead to major asset theft. In 2023, the MOVEit file transfer software had a single unpatched application led to the theft of sensitive data across hundreds of international companies [5]. A formalized Patch Management policy acts as routine digital maintenance.

1. **Establish a Formalized Patch Policy:** Less severe updates can be handled in a routine schedule, but critical vulnerability patches should be implemented within a maximum of 72 hours of their release. Create a process for establishing patch timeframes.
2. **Utilize a Centralized Management Tool:** Employ a unified endpoint management (UEM) or patch management system to automate the deployment of updates across all company-owned devices (laptops, servers, etc.).
3. **Maintain a Comprehensive Asset Inventory:** Keep an inventory of all software and hardware, and their most recent updates. You cannot protect what you do not know you have.

Third-Party Risk Management – A Chain of Responsibility

A collaborative ecosystem, publishing today involves freelance editors, illustrators, narrators, and distributors. This ecosystem is vast and porous, where every connection to an external vendor represents a potential extension of the company, and as such, it creates a bigger attack surface . A breach at a small, less-secure design firm could provide attackers with trusted credentials to target your network directly. In late 2025, customer success platform Gainsight was exploited for its integration

with Google Salesforce, spreading to over 200 organizations and costing millions of dollars for each firm affected. **[6]** If a key publishing firm goes down, operations will be disrupted for anybody who relies on them, and cash flow will grind to a halt. Knowing who you're working with, and controlling what you can is extremely important. **The right steps can be taken with the following strategies:**

1. **Perform Security Vetting:** Integrate basic cybersecurity questionnaires into your vendor onboarding process, and perform verification checklists on current vendors. Anybody new should be quizzed on multi-factor authentication, data encryption practices, and incident response plans.
 2. **Define Security Requirements in Contracts:** Where possible, contractually obligate key partners (especially those handling unpublished manuscripts) to adhere to specific security standards, such as mandatory MFA and prompt reporting of any security incidents.
 3. **Limit and Monitor Third-Party Access:** Provide partners with the minimum access necessary via secure, monitored channels. Avoid giving permanent, broad network access. Use secure file-sharing portals with expiration dates on links and downloads instead of open network shares.
-

Conclusion

Evolving technology is a vast field of trial and error, testing, and adaptation. Publishers have fought a hard offensive battle in the world of technology. Fighting to stay current has costs, but the costs of falling behind are far greater. Strong, well thought out defensive strategies can create armor, holding together through impact. If staff are appropriately trained, given only the needed tools for the job, with plenty of backups, a plan to recover, a watchful eye on vendors, and diligently updating, we can prepare for the worst, and be ready for the future.

Sources

[1] – Indigo ransomware attack cost millions, company says

- Howard Solomon, IT World Canada, mirror via Financial Post, Jun 28 2023

<https://financialpost.com/technology/indigo-ransomware-attack-cost-millions-company-says>

[2] – CPI and The Agency suffer cyber attacks as publisher profits ‘hit significantly’

– Heloise Wood, The Bookseller, Feb 19 2025

<https://www.thebookseller.com/news/cpi-and-the-agency-suffer-cyber-attacks-as-publisher-profits-hit-significantly>

[3] – 2025 Ransomware Statistics

- Rob Sobers, Veronis, November 14 2025

<https://www.varonis.com/blog/ransomware-statistics>

[4] – The 2023 Rhysida Ransomware Attack on the British Library

Frank Houghton, Michael Winterburn, and Ken Oakley, March 17, 2025

<https://ital.corejournals.org/index.php/ital/article/view/17112/11928>

[5] – MOVEit Data Breach Hits US Government Contractor, Exposes Health Data of 8 to 11 Million People

Scott Ikeda, CPO Magazine, August 2 2023

<https://www.cpomagazine.com/cyber-security/moveit-data-breach-hits-us-government-contractor-exposes-health-data-of-8-to-11-million-people/>

[6] – ShinyHunters Breach Steals Data from 200+ Firms via Salesforce Flaw

John Marshall, WebProNews, November 24 2025

<https://www.webpronews.com/shinyhunters-breach-steals-data-from-200-firms-via-salesforce-flaw/>